ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.08

Checklist del baseline según el Grupo de Implementación asignado (CIS v8.1)

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.08 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. Checklist del baseline según el Grupo de Implementación asignado (CIS v8.1)..... 3
G.1 Salvaguardas IG1 por control (base común de todos los equipos)..... 4
G.2 Checklist del baseline (pre-poblado con las 153 salvaguardas de CIS Controls v8.1)..... 5
Supuestos declarados en este entregable..... 13
Conteo de cierre verificado..... 14
Distribución de los estados propuestos..... 14

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3 · baseline de 153 salvaguardas
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	viernes 6 de noviembre de 2026 (H4)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.08 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E08_Checklist_Baseline_IG_<Equipo>.docx (o .pdf).

3. Checklist del baseline según el Grupo de Implementación asignado (CIS v8.1)

El baseline del proyecto es el conjunto de salvaguardas del **IG asignado** a la organización en el catálogo, que es **IG3** en las veintisiete: 56 salvaguardas de higiene cibernética esencial (IG1), 74 más hasta 130 (IG2) y 23 más hasta las 153 de CIS Controls v8.1 (2024). Los grupos son acumulativos, de modo que un equipo IG2 mapea las 130 salvaguardas de IG1 e IG2, y un equipo IG3 mapea las 153. Para cada control fuera de los seis desarrollados a profundidad en E.07, el equipo completa el mapeo: por cada salvaguarda del IG asignado, una línea con la medida que la cubre en su organización y su estado (existente / existente parcial / cubierta por tercero / por implementar / al roadmap de E.10). La columna «Estado» lleva un solo valor: «existente», «existente parcial» y «cubierta por tercero» describen la situación actual —las dos primeras tomadas del bloque «Controles que ya existen» de la ficha y la tercera con contrato vigente—, y «por implementar» y «al roadmap» describen la propuesta del diseño. Una cláusula contractual aún no firmada deja la salvaguarda «por implementar», con la cláusula como medida.

Ejemplo resuelto de cátedra · entrega: viernes 6 de noviembre de 2026 (H4). El checklist contiene las 107 salvaguardas del baseline IG3 que quedan fuera de los seis controles desarrollados a profundidad en E.07 (controles 6, 7, 11, 12, 13 y 15, con 46 salvaguardas documentadas en sus tablas F.1). Comprobación de cierre: 41 salvaguardas IG1 aquí + 15 IG1 en E.07 = 56 · 107 + 46 = 153.

La tabla del entregable se completa con la medida que cubre cada salvaguarda en ENSA, su estado propuesto y la evidencia esperada; el número, el nombre y el grupo de implementación provienen del catálogo oficial de CIS Controls v8.1 (2024). En los perfiles con tecnología de operación la medida distingue la red de TI y la red OT, como ocurre aquí en los controles 1, 2, 4, 5, 8 y 10.

G.1 Salvaguardas IG1 por control (base común de todos los equipos)

Control CIS v8.1	Salvaguardas IG1	Salvaguardas IG1 a mapear
1 · Inventario y control de activos empresariales	2	Inventario detallado de activos (1.1) y tratamiento de activos no autorizados (1.2).
2 · Inventario y control de activos de software	3	Inventario de software (2.1), software soportado por el fabricante (2.2), tratamiento del no autorizado (2.3).
3 · Protección de datos	6	Proceso de gestión de datos (3.1), inventario (3.2), listas de acceso (3.3), retención (3.4), eliminación segura (3.5), cifrado en dispositivos de usuario final (3.6).
4 · Configuración segura de activos y software	7	Proceso de configuración segura (4.1), incluida la de dispositivos de red (4.2), y gestión de sesiones, firewalls y bloqueo (4.3–4.7).
5 · Gestión de cuentas	4	Inventario de cuentas (5.1), contraseñas únicas (5.2), baja de cuentas inactivas (5.3), restricción de privilegios de administrador (5.4).
6 · Gestión del control de acceso	5	Alta y baja de accesos (6.1–6.2), MFA para aplicaciones expuestas (6.3), redes (6.4) y acceso administrativo (6.5).
7 · Gestión continua de vulnerabilidades	4	Proceso de gestión (7.1) y de remediación (7.2), parcheo automatizado de SO (7.3) y de aplicaciones (7.4).
8 · Gestión de bitácoras de auditoría	3	Proceso de gestión de bitácoras (8.1), recolección (8.2) y almacenamiento adecuado (8.3).
9 · Protección de correo y navegador	2	Navegadores y clientes de correo soportados (9.1) y filtrado DNS (9.2).
10 · Defensas contra malware	3	Anti-malware desplegado (10.1), firmas actualizadas (10.2), autoejecución deshabilitada (10.3).
11 · Recuperación de datos	4	Proceso de recuperación (11.1), respaldos automatizados (11.2), protección de respaldos (11.3), copia aislada (11.4).
12 · Gestión de la infraestructura de red	1	Infraestructura de red actualizada y soportada (12.1).
13 · Monitoreo y defensa de la red	0	Sin salvaguardas IG1; sus once salvaguardas IG2 e IG3 entran al baseline por la asignación IG3.
14 · Concientización y capacitación en seguridad	8	Programa de concientización (14.1) y sus temas esenciales (14.2–14.8): ingeniería social, autenticación, manejo de datos, reportes de incidentes.
15 · Gestión de proveedores de servicios	1	Inventario de proveedores de servicios (15.1).
16 · Seguridad del software de aplicaciones	0	Sin salvaguardas IG1; sus catorce salvaguardas IG2 e IG3 entran al baseline por la asignación IG3.
17 · Gestión de respuesta a incidentes	3	Designación de responsables (17.1), contactos para reportar (17.2), proceso de reporte (17.3).
18 · Pruebas de penetración	0	Sin salvaguardas IG1; sus cinco salvaguardas IG2 e IG3 entran al baseline por la asignación IG3.

El total de la columna IG1 suma las 56 salvaguardas de la base común. La tabla G.2 trae las 153 salvaguardas de CIS Controls v8.1 (Center for Internet Security, 2024; documento oficial disponible sin costo, con registro, en https://www.cisecurity.org/controls/v8-1, y consultable en línea sin registro en el CIS Controls Navigator v8.1, https://www.cisecurity.org/controls/cis-controls-navigator; citado en la bibliografía con su edición y año) con su número, su nombre en traducción literal y su IG, de modo que el equipo no transcribe: elimina y completa. Las medidas de configuración segura citan la lista oficial de CIS Benchmarks (https://www.cisecurity.org/cis-benchmarks), cuyos PDF se descargan sin costo para uso no comercial, con registro, en https://learn.cisecurity.org/benchmarks.

G.2 Checklist del baseline (pre-poblado con las 153 salvaguardas de CIS Controls v8.1)

La tabla trae las 153 salvaguardas con número, nombre e IG. El equipo la reduce a su baseline en tres pasos: (1) elimina las filas de los seis controles desarrollados en E.07 (esas salvaguardas se documentan en la F.1 de cada control); (2) conserva las tres categorías de IG, porque el IG asignado es IG3 en las veintisiete organizaciones; (3) completa medida, estado y evidencia en cada fila restante. Comprobación de cierre: filas IG1 de esta tabla + salvaguardas IG1 de las seis F.1 de E.07 = 56; el total de ambas = 153, el IG3 asignado a todas las organizaciones del catálogo. Ejemplo de llenado (RHM, IG3): 1.1 → medida «Inventario de servidores, estaciones y dispositivos IoMT en la CMDB de RHM, actualizado por descubrimiento pasivo» · estado «Por implementar» · evidencia «Reporte mensual de la CMDB».

Control	Salvaguarda (n.º y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
1	1.1 Inventario detallado de activos empresariales	IG1	Inventario único de activos de TI en la herramienta de gestión de servicios, ampliado a los activos de la red OT y a los concentradores AMI, con dueño y proceso que sostiene	Existente parcial: cubre la red corporativa; la red OT queda fuera (brecha B-03)	Reporte mensual del inventario con conteo por red
1	1.2 Tratamiento de activos no autorizados	IG1	Procedimiento de tratamiento del activo no autorizado: aislamiento en TI y, en OT, notificación al centro de control antes de cualquier acción	Por implementar	Registro de activos no autorizados detectados y su disposición
1	1.3 Herramienta de descubrimiento activo	IG2	Descubrimiento activo semanal en la red corporativa, prohibido en la red OT por su efecto sobre los equipos de control	Por implementar	Reporte semanal de descubrimiento de la red de TI
1	1.4 Registro DHCP para actualizar el inventario	IG2	Actualización del inventario con los registros de asignación de direcciones de la red corporativa	Por implementar	Conciliación mensual entre asignaciones y el inventario
1	1.5 Herramienta de descubrimiento pasivo	IG3	Descubrimiento pasivo permanente en la red OT con la misma sonda del control 13, sin inyección de tráfico	Al roadmap (E.10, corto plazo, junto con la sonda de detección)	Inventario de activos OT generado por la sonda
2	2.1 Inventario de software	IG1	Inventario de software de servidores y estaciones de TI, y de las versiones de firmware de los equipos de control y HMI	Existente parcial: el software de TI está inventariado, el firmware de OT no	Listado de software y firmware con versión y fecha
2	2.2 Software soportado por el fabricante	IG1	Verificación de que todo software y firmware cuenta con soporte vigente del fabricante, con excepción documentada para las versiones que el fabricante del SCADA aún soporta bajo contrato	Por implementar	Reporte de software fuera de soporte con plan de sustitución
2	2.3 Tratamiento de software no autorizado	IG1	Retiro del software no autorizado en estaciones de TI; en OT, prohibición de instalación y revisión en cada ventana de mantenimiento	Por implementar	Registro de hallazgos y desinstalaciones
2	2.4 Herramientas automatizadas de inventario de software	IG2	Agente de inventario de software en estaciones y servidores de la red corporativa	Por implementar	Reporte automatizado mensual
2	2.5 Lista de software autorizado	IG2	Lista de software autorizado por perfil de puesto, aprobada por TI/TO	Por implementar	Lista vigente con fecha de aprobación

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
2	2.6 Lista de bibliotecas autorizadas	IG2	Lista de bibliotecas autorizadas para el desarrollo interno y para el portal de clientes	Cubierta por tercero: Soluciones Ánfora S.A. de C.V., contrato MSA-2025-014, anexo de seguridad cláusula 9.3, que obliga a mantener y entregar la lista de componentes	Lista de bibliotecas autorizadas entregada por el proveedor cada trimestre
2	2.7 Lista de scripts autorizados	IG3	Control de los scripts de automatización de TI, con repositorio y aprobación	Al roadmap (E.10, largo plazo)	Repositorio de scripts con historial de aprobación
3	3.1 Proceso de gestión de datos	IG1	Proceso de gestión de datos con el ciclo de vida de los datos de clientes y de los datos de operación de la red	Por implementar	Procedimiento aprobado por la Gerencia General
3	3.2 Inventario de datos	IG1	Inventario de datos derivado del inventario de activos de E.04, con la marca de datos personales sujetos a la LPDP	Existente parcial: el inventario de activos ya distingue datos personales; falta el detalle por repositorio	Inventario de datos con clasificación y ubicación
3	3.3 Listas de control de acceso a datos	IG1	Listas de control de acceso por repositorio: base de clientes, curva de carga, configuración del SCADA	Existente parcial: aplicadas en el sistema comercial, ausentes en los repositorios de operación	Matriz de accesos por repositorio con revisión semestral
3	3.4 Retención de datos	IG1	Política de retención: datos de consumo por cinco años, bitácoras por un año, respaldos del SCADA por treinta días	Por implementar	Política de retención aprobada y reporte de cumplimiento
3	3.5 Eliminación segura de datos	IG1	Eliminación segura de medios y equipos dados de baja, incluidos los medidores y concentradores retirados	Por implementar	Actas de destrucción con número de serie
3	3.6 Cifrado en dispositivos de usuario final	IG1	Cifrado de disco en las estaciones de trabajo del personal administrativo y en los equipos portátiles de campo	Por implementar	Reporte de estado de cifrado por equipo
3	3.7 Esquema de clasificación de datos	IG2	Esquema de clasificación de cuatro niveles —pública, interna, confidencial, restringida— tal como se aplicó en E.04	Por implementar: el esquema se definió y se aplicó al inventario de E.04, y la ficha no lo registra entre los controles que ya existen	Documento del esquema aprobado por la Gerencia General y su aplicación en el inventario
3	3.8 Documentación de flujos de datos	IG2	Documentación de los flujos de datos entre AMI, sistema comercial, portal de clientes y pasarela de pagos	Por implementar	Diagrama de flujos de datos versionado
3	3.9 Cifrado de medios removibles	IG2	Cifrado de medios removibles usados para transferir configuraciones al entorno de control	Por implementar	Registro de medios autorizados y su estado de cifrado

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
3	3.10 Cifrado de datos sensibles en tránsito	IG2	Cifrado en tránsito de los datos de consumo entre concentradores AMI y la cabecera, y de las extracciones del sistema comercial	Existente parcial: la cabecera AMI cifra, las extracciones del sistema comercial viajan sin cifrar	Reporte de configuración de los canales
3	3.11 Cifrado de datos sensibles en reposo	IG2	Cifrado en reposo de la base de datos de clientes y de los respaldos	Por implementar	Evidencia de configuración de cifrado de la base y del respaldo
3	3.12 Segmentación del procesamiento y almacenamiento por sensibilidad	IG2	Separación del procesamiento y el almacenamiento de datos de clientes respecto de los datos de operación de la red	Existente parcial: separados por sistema, sin segmentación de almacenamiento	Diagrama de segmentación de datos
3	3.13 Solución de prevención de fuga de datos	IG3	Prevención de fuga de datos en las salidas del sistema comercial y del correo corporativo	Al roadmap (E.10, largo plazo)	Reporte de eventos de prevención de fuga
3	3.14 Registro de acceso a datos sensibles	IG3	Registro de acceso a los repositorios de datos sensibles, integrado a la plataforma central de alertas	Al roadmap (E.10, largo plazo, tras la centralización de bitácoras)	Bitácora de accesos a datos sensibles
4	4.1 Proceso de configuración segura	IG1	Proceso de configuración segura con líneas base documentadas para servidores, estaciones, equipos de red y estaciones HMI	Por implementar	Líneas base aprobadas y registro de desviaciones
4	4.2 Configuración segura de la infraestructura de red	IG1	Configuración segura de la infraestructura de red, coordinada con el control 12 desarrollado en E.07	Por implementar	Configuración de referencia de los equipos de red
4	4.3 Bloqueo automático de sesión	IG1	Bloqueo automático de sesión en estaciones administrativas; en las estaciones HMI del centro de control se aplica bloqueo con excepción documentada por seguridad operativa	Por implementar	Configuración vigente y excepción aprobada
4	4.4 Firewall en servidores	IG1	Cortafuegos local activo en servidores de la red corporativa	Por implementar	Reporte de estado por servidor
4	4.5 Firewall en dispositivos de usuario final	IG1	Cortafuegos local activo en estaciones de usuario final	Existente parcial: activo en el nuevo parque de equipos, ausente en los heredados	Reporte de estado por equipo
4	4.6 Gestión segura de activos y software	IG1	Gestión segura de activos y software mediante las líneas base y el control de cambios	Por implementar	Registro de cambios de configuración aprobados
4	4.7 Gestión de cuentas por defecto	IG1	Cambio de las cuentas y credenciales de fábrica en equipos de red, concentradores AMI y equipos de control	Por implementar	Acta de cambio de credenciales por lote de equipos
4	4.8 Desinstalar o deshabilitar servicios innecesarios	IG2	Desinstalación de servicios innecesarios en servidores y en los equipos de la cabecera de medición	Por implementar	Comparación contra la línea base de servicios
4	4.9 Servidores DNS de confianza	IG2	Uso exclusivo de servidores de nombres corporativos con filtrado	Por implementar	Configuración de resolución de nombres en estaciones
4	4.10 Bloqueo automático de dispositivos portátiles	IG2	Bloqueo automático en los dispositivos portátiles de las cuadrillas de campo	Por implementar	Política de gestión de dispositivos y su reporte

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
4	4.11 Borrado remoto de dispositivos portátiles	IG2	Borrado remoto de los dispositivos portátiles de campo ante pérdida o robo	Al roadmap (E.10, mediano plazo)	Registro de borrados ejecutados
4	4.12 Espacios de trabajo separados en móviles	IG3	Separación del espacio de trabajo corporativo en los dispositivos móviles del personal técnico	Al roadmap (E.10, mediano plazo)	Configuración de la plataforma de gestión móvil
5	5.1 Inventario de cuentas	IG1	Inventario de cuentas de TI y de las cuentas locales de las estaciones HMI y de los equipos de control	Existente parcial: cubre el directorio corporativo; las cuentas locales de OT no están inventariadas	Inventario de cuentas con dueño y última revisión
5	5.2 Contraseñas únicas	IG1	Contraseñas únicas por cuenta, con longitud mínima y prohibición de reutilización entre TI y OT	Existente parcial: la política existe en TI y no se aplica en los equipos de control	Política vigente y reporte de cumplimiento
5	5.3 Deshabilitar cuentas inactivas	IG1	Deshabilitación de cuentas inactivas por más de cuarenta y cinco días	Por implementar	Reporte mensual de cuentas inactivas y su disposición
5	5.4 Restringir privilegios de administrador a cuentas dedicadas	IG1	Privilegios de administrador solo en cuentas dedicadas, distintas de la cuenta de uso diario	Por implementar	Listado de cuentas administrativas y su titular
5	5.5 Inventario de cuentas de servicio	IG2	Inventario de cuentas de servicio del sistema comercial, del OMS y de las integraciones con la cabecera AMI	Por implementar	Inventario de cuentas de servicio con dueño y propósito
5	5.6 Gestión centralizada de cuentas	IG2	Gestión centralizada de cuentas en el directorio corporativo, con la excepción de las cuentas locales de emergencia del entorno de control	Existente parcial: centralizada en TI; el entorno OT mantiene cuentas locales por diseño	Reporte de cuentas fuera de la gestión centralizada
8	8.1 Proceso de gestión de bitácoras	IG1	Proceso de gestión de bitácoras con alcance sobre TI y OT, que define qué se registra, dónde se conserva y quién lo revisa	Por implementar	Procedimiento aprobado
8	8.2 Recolección de bitácoras	IG1	Recolección de bitácoras de servidores, equipos de red, directorio, sistema comercial y servidores del SCADA	Por implementar	Inventario de fuentes con estado de reporte
8	8.3 Almacenamiento adecuado de bitácoras	IG1	Almacenamiento dimensionado para noventa días en línea y un año en archivo	Por implementar	Reporte de capacidad y retención efectiva
8	8.4 Sincronización de tiempo	IG2	Sincronización de tiempo contra una fuente única para TI y OT, requisito para correlacionar maniobras y eventos	Por implementar	Reporte de desviación de reloj por equipo
8	8.5 Bitácoras detalladas	IG2	Bitácoras detalladas con usuario, origen, destino y resultado en los sistemas de los procesos críticos	Por implementar	Muestra de registros con los campos exigidos
8	8.6 Bitácoras de consultas DNS	IG2	Registro de las consultas de resolución de nombres de la red corporativa	Al roadmap (E.10, largo plazo)	Bitácora de consultas disponible para consulta
8	8.7 Bitácoras de solicitudes URL	IG2	Registro de las solicitudes de navegación del personal administrativo	Al roadmap (E.10, largo plazo)	Bitácora de navegación con retención declarada
8	8.8 Bitácoras de línea de comandos	IG2	Registro de línea de comandos en servidores y en las estaciones de ingeniería del entorno de control	Al roadmap (E.10, largo plazo)	Muestra de registros de comandos

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
8	8.9 Centralización de bitácoras	IG2	Centralización de bitácoras en la plataforma que el control 13 implanta	Por implementar	Reporte de fuentes centralizadas
8	8.10 Retención de bitácoras	IG2	Retención de un año para las bitácoras de los procesos críticos y de los accesos de proveedores	Por implementar	Política de retención y verificación de su aplicación
8	8.11 Revisión de bitácoras	IG2	Revisión periódica de bitácoras, con foco en accesos administrativos y en maniobras fuera de horario	Por implementar	Acta de revisión mensual con hallazgos
8	8.12 Bitácoras de proveedores de servicios	IG3	Recepción y conservación de las bitácoras de acceso de los proveedores que operan sobre los sistemas de ENSA	Cubierta por tercero: fabricante del sistema SCADA, contrato SOP-2024-007, cláusula 11 de trazabilidad del anexo de seguridad, que obliga a entregar el registro de cada sesión de soporte	Registro de sesiones de soporte entregado mensualmente por el fabricante
9	9.1 Navegadores y clientes de correo soportados	IG1	Navegador y cliente de correo soportados y actualizados en el parque de estaciones administrativas	Existente: el parque usa versiones soportadas con actualización automática	Reporte de versiones por equipo
9	9.2 Filtrado DNS	IG1	Filtrado de resolución de nombres con categorías bloqueadas en la red corporativa	Por implementar	Reporte de dominios bloqueados y consultas denegadas
9	9.3 Filtros de URL en red	IG2	Filtrado de direcciones web en la salida a internet del personal administrativo	Por implementar	Configuración del filtro y reporte de bloqueos
9	9.4 Restricción de extensiones de navegador y correo	IG2	Restricción de extensiones y complementos no autorizados en navegador y correo	Por implementar	Lista de extensiones permitidas y reporte de cumplimiento
9	9.5 DMARC	IG2	Registro de política de autenticación de correo para el dominio de ENSA, con rechazo del correo suplantado	Por implementar	Reporte de la política publicada y de los informes recibidos
9	9.6 Bloqueo de tipos de archivo innecesarios	IG2	Bloqueo de tipos de archivo innecesarios en la pasarela de correo	Por implementar	Configuración de la pasarela y reporte de bloqueos
9	9.7 Antimalware en el servidor de correo	IG3	Análisis antimalware en el servidor de correo antes de la entrega	Existente parcial: el filtro opera con firmas, sin análisis en entorno aislado	Reporte mensual de correo bloqueado
10	10.1 Antimalware desplegado	IG1	Antimalware desplegado en servidores y estaciones de la red corporativa; en las estaciones HMI se aplica la solución que el fabricante del SCADA autoriza	Existente parcial: desplegado en TI, ausente en el entorno de control	Reporte de cobertura por equipo
10	10.2 Actualización automática de firmas	IG1	Actualización automática de firmas, con distribución interna para los equipos del entorno de control sin salida a internet	Existente parcial: automática en TI; manual y esporádica en OT	Reporte de antigüedad de firmas

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
10	10.3 Deshabilitar autoejecución de medios removibles	IG1	Deshabilitación de la autoejecución de medios removibles en estaciones de TI y de ingeniería del centro de control	Por implementar	Configuración vigente por línea base
10	10.4 Escaneo automático de medios removibles	IG2	Análisis automático de todo medio removible al conectarse, medida crítica por el uso de medios para trasladar configuraciones al entorno OT	Por implementar	Registro de análisis ejecutados
10	10.5 Funciones antiexplotación	IG2	Funciones antiexplotación habilitadas en servidores y estaciones de la red corporativa	Por implementar	Reporte de configuración por equipo
10	10.6 Gestión centralizada del antimalware	IG2	Gestión centralizada del antimalware con consola única para TI y, en la medida que el fabricante lo permita, para las estaciones del entorno de control	Por implementar	Consola con inventario de agentes y su estado
10	10.7 Antimalware basado en comportamiento	IG2	Detección basada en comportamiento en servidores de los procesos críticos	Al roadmap (E.10, mediano plazo)	Reporte de detecciones por comportamiento
14	14.1 Programa de concientización en seguridad	IG1	Programa anual de concientización con calendario, contenidos y registro de asistencia, dirigido a los 550 empleados	Por implementar	Plan anual aprobado y registro de participación
14	14.2 Reconocer ataques de ingeniería social	IG1	Módulo de reconocimiento de ingeniería social, con énfasis en la suplantación asistida por inteligencia artificial que el riesgo R-08 describe	Por implementar	Material del módulo y resultados de la evaluación
14	14.3 Buenas prácticas de autenticación	IG1	Módulo de buenas prácticas de autenticación, incluida la operación del segundo factor	Por implementar	Registro de participación y evaluación
14	14.4 Buenas prácticas de manejo de datos	IG1	Módulo de manejo de datos personales de clientes conforme a la LPDP	Por implementar	Material del módulo y registro de participación
14	14.5 Causas de exposición no intencional de datos	IG1	Módulo sobre causas de exposición no intencional de datos, dirigido al personal comercial y del centro de contacto	Por implementar	Registro de participación por área
14	14.6 Reconocer y reportar incidentes	IG1	Módulo de reconocimiento y reporte de incidentes, con el canal y el plazo de reporte declarados	Por implementar	Registro de participación y estadística de reportes recibidos
14	14.7 Identificar y reportar actualizaciones faltantes	IG1	Módulo sobre identificación y reporte de actualizaciones faltantes en el equipo asignado	Por implementar	Registro de participación
14	14.8 Riesgos de conectarse a redes inseguras	IG1	Módulo sobre riesgos de conectarse a redes inseguras, dirigido al personal de campo con dispositivos portátiles	Por implementar	Registro de participación del personal de campo
14	14.9 Capacitación por rol	IG2	Capacitación por rol: operadores del centro de control, administradores de TI/TO, personal comercial y cuadrillas	Al roadmap (E.10, largo plazo, tras el programa general)	Matriz de capacitación por rol con su cumplimiento
16	16.1 Proceso de desarrollo seguro	IG2	Proceso de desarrollo seguro aplicado al portal de clientes y a las integraciones con la pasarela de pagos	Cubierta por tercero: Soluciones Ánfora S.A. de C.V., contrato MSA-2025-014, anexo de seguridad cláusula 9.1, que obliga a un ciclo de vida de desarrollo seguro documentado	Descripción del ciclo de vida y evidencia de su aplicación por entrega

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
16	16.2 Proceso para aceptar y atender vulnerabilidades de software	IG2	Proceso para recibir y atender reportes de vulnerabilidades del portal de clientes	Cubierta por tercero: Soluciones Ánfora, contrato MSA-2025-014, cláusula 9.2, con acuerdo de atención de 30 días para severidad alta	Registro de vulnerabilidades reportadas y su cierre
16	16.3 Análisis de causa raíz de vulnerabilidades	IG2	Análisis de causa raíz de las vulnerabilidades encontradas en el portal	Cubierta por tercero: Soluciones Ánfora, cláusula 9.2 del mismo anexo	Informe de causa raíz por vulnerabilidad de severidad alta
16	16.4 Inventario de componentes de terceros	IG2	Inventario de componentes de terceros del portal de clientes	Cubierta por tercero: Soluciones Ánfora, cláusula 9.3	Inventario de componentes entregado en cada versión
16	16.5 Componentes de terceros actualizados y confiables	IG2	Componentes de terceros actualizados y provenientes de fuentes confiables	Cubierta por tercero: Soluciones Ánfora, cláusula 9.3, con obligación de actualizar componentes con vulnerabilidad conocida	Reporte trimestral de estado de componentes
16	16.6 Sistema de calificación de severidad	IG2	Sistema de calificación de severidad de vulnerabilidades de aplicación	Cubierta por tercero: Soluciones Ánfora, cláusula 9.2, con la escala acordada en el contrato	Calificación asignada a cada hallazgo
16	16.7 Plantillas de configuración endurecida para infraestructura de aplicaciones	IG2	Plantillas de configuración endurecida para la infraestructura que soporta el portal	Por implementar: la infraestructura es de ENSA y su endurecimiento corresponde al control 4	Línea base de configuración del servidor del portal
16	16.8 Separación de producción y no producción	IG2	Separación de los entornos de producción y de no producción del portal	Cubierta por tercero: Soluciones Ánfora, cláusula 9.4, que prohíbe usar datos reales de clientes en pruebas	Declaración de entornos y evidencia de anonimización
16	16.9 Capacitación de desarrolladores en seguridad	IG2	Capacitación en seguridad del personal de desarrollo	Cubierta por tercero: Soluciones Ánfora, cláusula 9.5, con constancia anual	Constancias de capacitación del equipo asignado
16	16.10 Principios de diseño seguro	IG2	Aplicación de principios de diseño seguro en el portal y en sus interfaces	Cubierta por tercero: Soluciones Ánfora, cláusula 9.1	Documento de diseño con los principios aplicados

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
16	16.11 Módulos o servicios verificados para componentes de seguridad	IG2	Uso de módulos verificados para autenticación, cifrado y manejo de sesión	Cubierta por tercero: Soluciones Ánfora, cláusula 9.1	Listado de módulos de seguridad empleados
16	16.12 Verificaciones de seguridad a nivel de código	IG3	Verificaciones de seguridad a nivel de código en el ciclo de entrega del portal	Cubierta por tercero: Soluciones Ánfora, cláusula 9.6, con reporte por versión entregada	Reporte de análisis de código por versión
16	16.13 Pruebas de penetración de aplicaciones	IG3	Pruebas de penetración de la aplicación antes de cada versión mayor	Cubierta por tercero: Vector Security S.A. de C.V., contrato SVC-2026-003, cláusula 6, independiente del desarrollador	Informe de prueba con hallazgos y su remediación
16	16.14 Modelado de amenazas	IG3	Modelado de amenazas del portal y de la integración con la pasarela de pagos	Al roadmap (E.10, largo plazo, con acompañamiento del proveedor)	Documento de modelado de amenazas
17	17.1 Personal designado para gestionar incidentes	IG1	Designación formal del personal que gestiona incidentes: Jefatura de Seguridad, analista de TI y analista de TO, con turno de guardia	Por implementar	Designación firmada y calendario de guardias
17	17.2 Información de contacto para reportar	IG1	Información de contacto para reportar incidentes, publicada al personal y a los proveedores	Por implementar	Directorio de contacto publicado y su fecha
17	17.3 Proceso empresarial de reporte	IG1	Proceso empresarial de reporte de incidentes con canal único y plazo declarado	Por implementar	Procedimiento aprobado y estadística de reportes
17	17.4 Proceso de respuesta a incidentes	IG2	Proceso de respuesta a incidentes con fases, criterios de severidad y decisiones que exigen a la dirección, incluida la notificación de brechas en 72 horas de la LPDP	Por implementar	Plan de respuesta aprobado por la Gerencia General
17	17.5 Roles y responsabilidades clave	IG2	Roles y responsabilidades durante la respuesta, coherentes con la RACI de E.06, con la Gerencia de Operaciones de Red como decisora del paso a operación manual	Por implementar	Matriz de roles del plan de respuesta
17	17.6 Mecanismos de comunicación durante la respuesta	IG2	Mecanismos de comunicación durante la respuesta, con canal alterno independiente del correo corporativo	Por implementar	Directorio de comunicación de crisis y prueba anual
17	17.7 Ejercicios periódicos	IG2	Ejercicios periódicos de respuesta, con al menos un ejercicio anual sobre el escenario de compromiso del entorno de control	Al roadmap (E.10, mediano plazo)	Informe del ejercicio con lecciones aprendidas
17	17.8 Revisiones posincidente	IG2	Revisión posincidente con acciones correctivas trazadas al roadmap	Por implementar	Acta de revisión posincidente
17	17.9 Umbrales de incidente	IG3	Umbrales que definen cuándo un evento se declara incidente, diferenciados para TI y para OT	Por implementar	Tabla de umbrales aprobada

Control	Salvaguarda (n.° y nombre)	IG	Medida que la cubre en la organización	Estado	Evidencia esperada
18	18.1 Programa de pruebas de penetración	IG2	Programa anual de pruebas de penetración con alcance, frecuencia y reglas de enfrentamiento, que excluye pruebas activas sobre el sistema de control en operación	Cubierta por tercero: Vector Security S.A. de C.V., contrato SVC-2026-003, cláusula 3, con programa anual aprobado por ENSA	Programa anual firmado y calendario de ejecución
18	18.2 Pruebas de penetración externas periódicas	IG2	Prueba de penetración externa anual sobre los servicios publicados, incluido el portal de clientes	Cubierta por tercero: Vector Security, contrato SVC-2026-003, cláusula 4	Informe anual de prueba externa
18	18.3 Remediación de hallazgos de pruebas	IG2	Remediación de los hallazgos de las pruebas, con plazos por severidad y verificación de cierre	Por implementar: la remediación es responsabilidad de ENSA y de Soluciones Ánfora según el componente	Registro de hallazgos con estado y fecha de cierre
18	18.4 Validación de medidas de seguridad	IG3	Validación de que las medidas de seguridad detectan y bloquean las técnicas empleadas en las pruebas	Al roadmap (E.10, largo plazo, cuando el monitoreo del control 13 esté en régimen)	Informe de validación con técnicas detectadas
18	18.5 Pruebas de penetración internas periódicas	IG3	Prueba de penetración interna periódica, con alcance sobre la red corporativa y la zona intermedia, sin tocar la red OT en operación	Cubierta por tercero: Vector Security, contrato SVC-2026-003, cláusula 5, con ejecución en ventana acordada	Informe de prueba interna con hallazgos

Conteo de referencia de la tabla completa: 153 filas = 56 IG1 + 74 IG2 + 23 IG3; por control: 1 (5) · 2 (7) · 3 (14) · 4 (12) · 5 (6) · 6 (8) · 7 (7) · 8 (12) · 9 (7) · 10 (7) · 11 (5) · 12 (8) · 13 (11) · 14 (9) · 15 (7) · 16 (14) · 17 (9) · 18 (5). Estados admitidos: existente (solo la medida que el bloque «Controles que ya existen» de la ficha de datos del cliente describe con la cobertura que pide la salvaguarda; toda salvaguarda que la ficha no menciona toma otro de los estados admitidos, y cero existentes es un resultado válido en organizaciones de madurez baja) · existente parcial, cuando la ficha describe la medida con cobertura incompleta, con la brecha residual declarada, que pasa a E.10 · cubierta por tercero, cuando la salvaguarda se cumple a través de un proveedor y la organización no la ejecuta, con el proveedor, la cláusula contractual que la hace exigible y la evidencia que el proveedor entrega nombrados en la fila · por implementar · al roadmap (E.10). En perfiles con tecnología de operación, la medida distingue la red de TI y la red OT.

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
S-15	Soluciones Ánfora S.A. de C.V. desarrolla y mantiene el portal de clientes bajo el contrato MSA-2025-014, con anexo de seguridad renegociado en 2026	El perfil declara un portal de clientes sin describir quién lo desarrolla; el proyecto necesita nombrar al responsable de las salvaguardas del control 16
S-16	Vector Security S.A. de C.V. ejecuta las pruebas de penetración bajo el contrato SVC-2026-003	El perfil no declara capacidad interna de pruebas ofensivas; la práctica del sector es contratarlas de forma independiente
S-17	El contrato de soporte del fabricante del sistema SCADA es el SOP-2024-007 y admite la incorporación del anexo de seguridad en su renovación	El perfil declara sistemas SCADA de Siemens con soporte del fabricante, sin detallar el instrumento contractual

Conteo de cierre verificado

Comprobación	Resultado
Salvaguardas en este checklist	107
Salvaguardas documentadas en las tablas F.1 de los seis controles de E.07	46 (control 6: 8 · control 7: 7 · control 11: 5 · control 12: 8 · control 13: 11 · control 15: 7)
Total del baseline	107 + 46 = 153, el IG3 asignado a ENSA
Salvaguardas IG1 en este checklist	41
Salvaguardas IG1 en las F.1 de E.07	15
Total IG1	41 + 15 = 56, la base común de higiene cibernética esencial

Distribución de los estados propuestos

Estado	Salvaguardas	Lectura del resultado
Existente	1	El navegador y el cliente de correo soportados (9.1), que la ficha registra en el bloque «Controles que ya existen»
Existente parcial	13	Casi todas describen la misma brecha: la medida opera en la red de TI y no alcanza a la red OT
Cubierta por tercero	17	Doce del control 16 y la 2.6, a cargo de la fábrica de software del portal; tres del control 18, a cargo de la firma de pruebas; y la 8.12, a cargo del fabricante del sistema SCADA
Por implementar	62	El grueso del baseline, que el roadmap de E.10 ordena en el corto y el mediano plazo
Al roadmap (E.10)	14	Salvaguardas cuya ejecución depende de una capacidad que aún no existe: centralización de bitácoras, monitoreo en régimen o gestión de dispositivos móviles

Los estados «existente parcial» y la 9.1 «existente» salen del bloque «Controles que ya existen» de la ficha de datos del cliente: la ficha describe esas medidas en la red de TI sin alcanzar la red OT. Una salvaguarda existente en un baseline de 153 es un resultado coherente con el perfil: ENSA declara controles básicos en la red de TI y una seguridad reactiva en la red OT. El equipo marcó como existente solo lo que la ficha registra entre los controles que

ya existen, y por eso el checklist es una fotografía fiel del estado actual. Las diecisiete salvaguardas cubiertas por tercero nombran proveedor, cláusula contractual y evidencia exigible: la responsabilidad se traslada con un contrato, y la obligación de verificarla queda en ENSA a través del control 15.